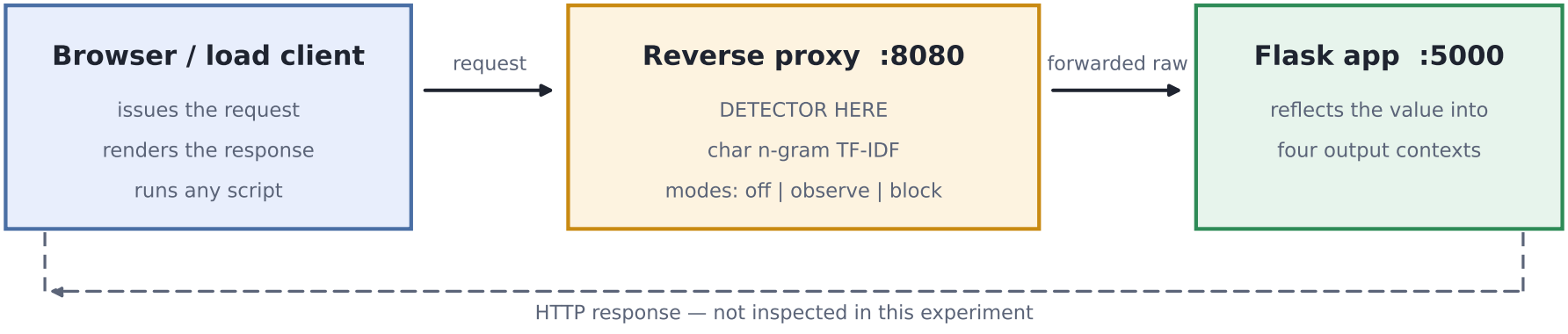
Figure 1 Detector location and available information

Local experiment, plaintext HTTP over 127.0.0.1. The detector runs inline in the reverse proxy.



information available at the detection point

Visible to the detector

+ HTTP method, path, query string
+ request headers, cookies, body
+ the once-decoded parameter value
+ timing and byte counts

NOT visible to the detector

– which output context the value reaches
– whether the browser executes it
– whether a user ever triggers the handler
– the URL fragment (never sent in the request)
– response body, unless also inspected

Measured consequence: identical request content is scored identically, yet the same value is inert at /reflect-text and executes at /reflect-html.

Under TLS this inspection point must sit at or after authorised termination; a passive encrypted-traffic monitor sees none of the above.